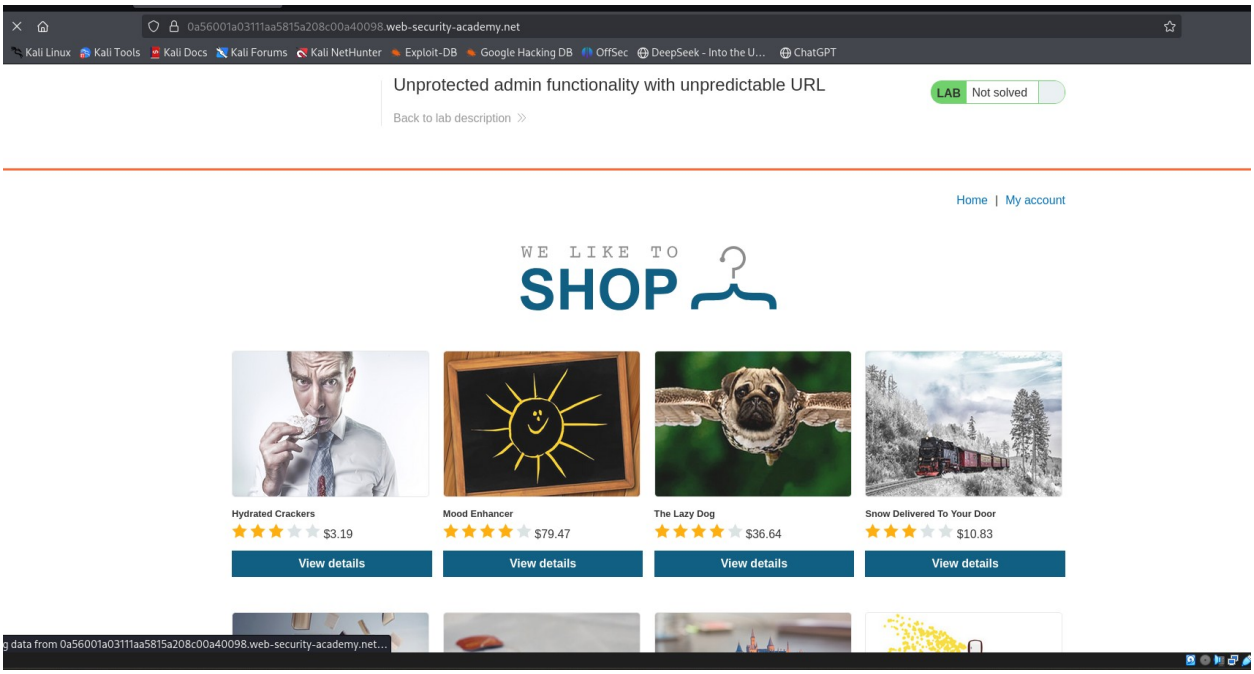
LAB ASSIGNMENT 02

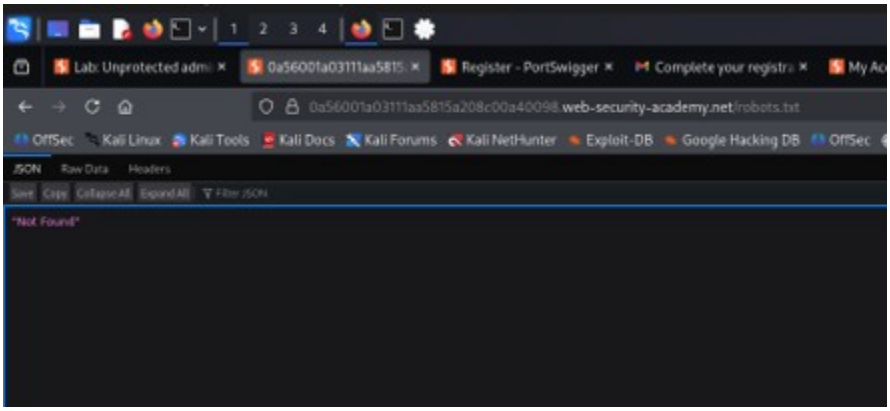
NAME: M AHMED ABBAS
Reg : FA23-BCS-152
SUBMITTED TO: Sir Salman Khan
SECTION: BCS-6C
Assign: Lab 6 Activites and Tasks
DATE: 04-04-2026

Activity 1: Find Hidden Admin Panel

Website



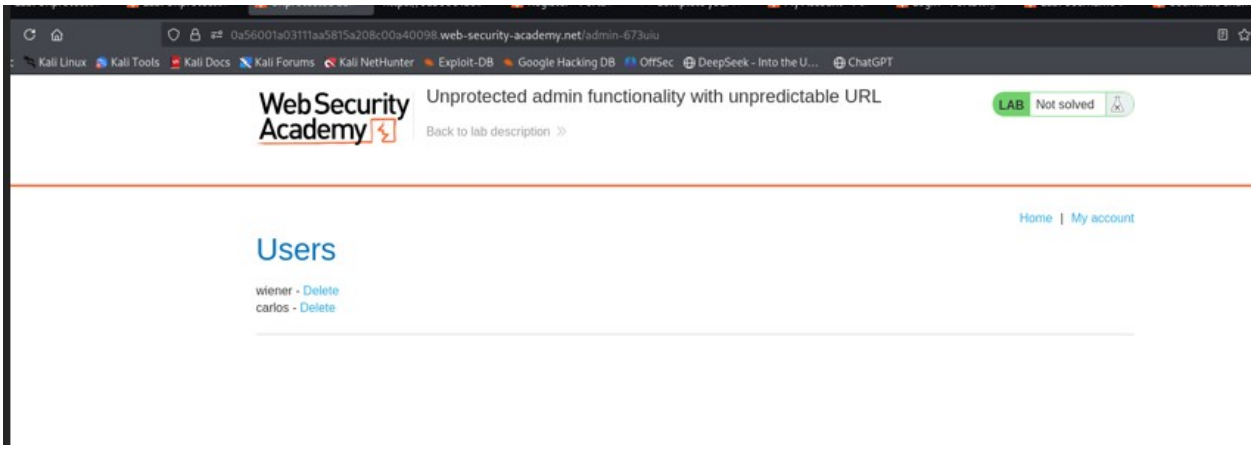
URL NOT FOUND :



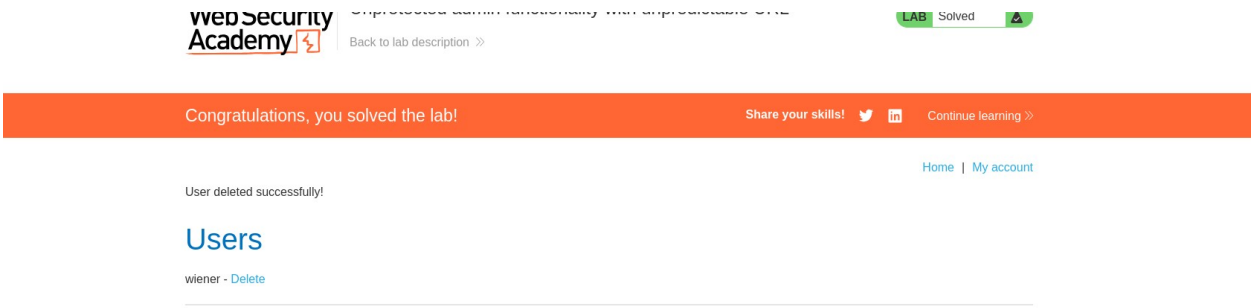
Found Admin url after going to inspect :

```
var isAdmin = false;
if (isAdmin) {
    var topLinksTag = document.getElementsByClassName("top-links")[0];
    var adminPanelTag = document.createElement('a');
    adminPanelTag.setAttribute('href', '/admin-673uiu');
    adminPanelTag.innerText = 'Admin panel';
    topLinksTag.append(adminPanelTag);
    var pTag = document.createElement('p');
    pTag.innerText = '|';
```

Inside the admin panel now

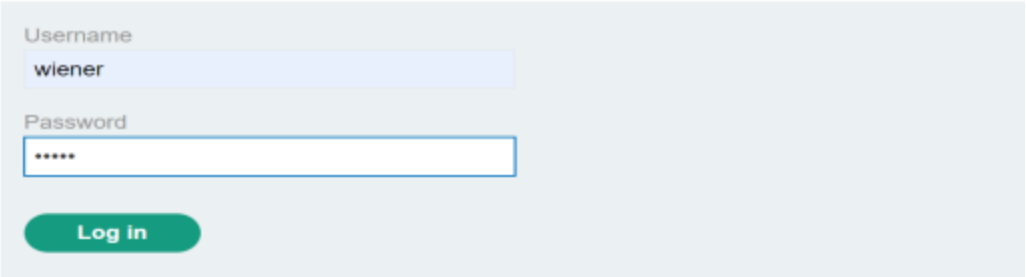


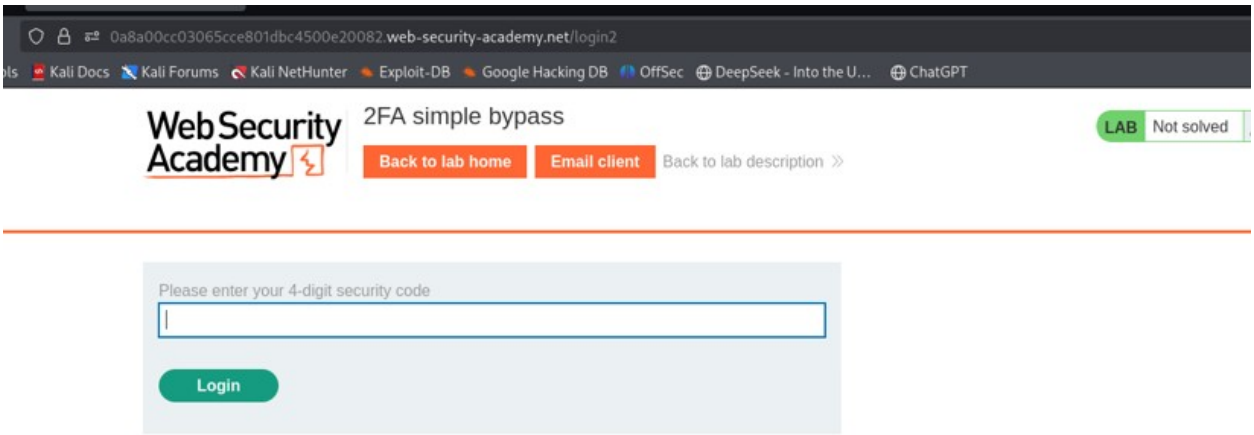
Task is done



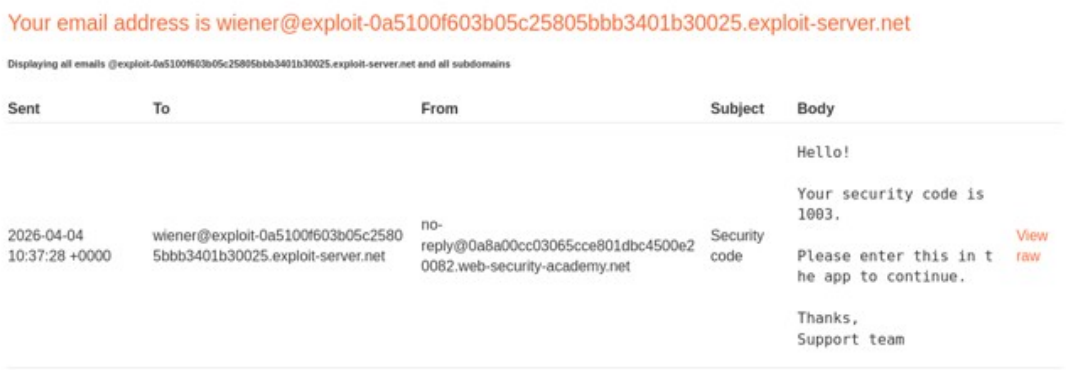
Activity 2: Bypassing two factor authentication

Bypassing two factor authentication Step#1 Open Browser in Burp Suite by heading to the proxy section Step#2 Open the Lab by heading to https://portswigger.net/web-security/authentication/multifactor/lab- 2fa-simple-bypass in Burp Suite's browser

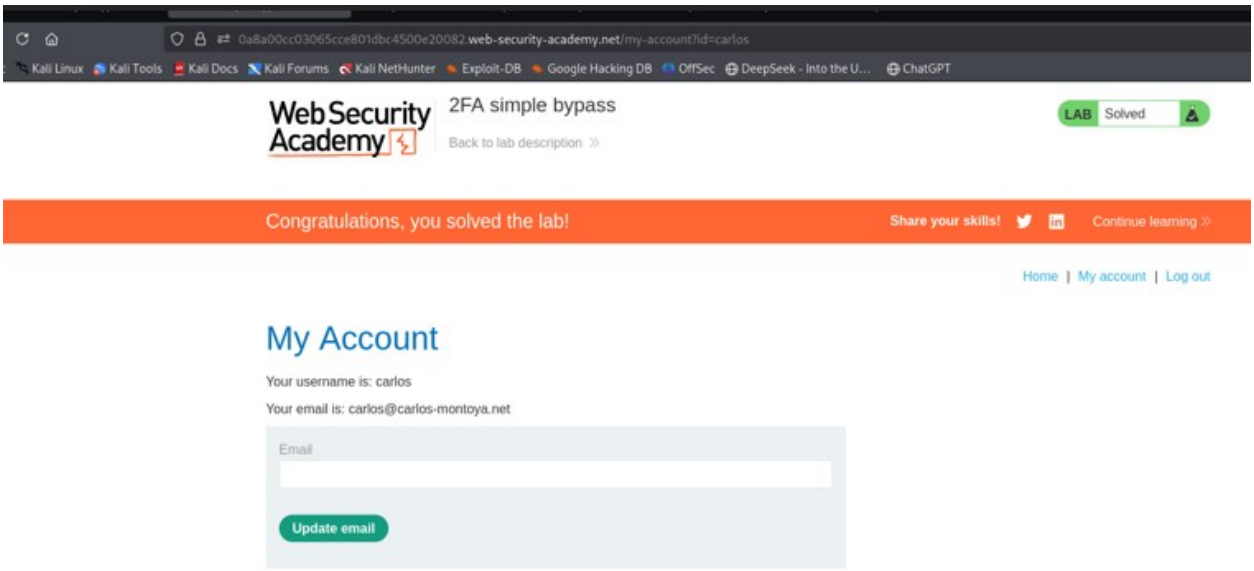




I received the security code



Two factor bypassed



Activity 3: Step 1: Install GnuPG

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sudo apt install gnupg
[sudo] password for kali:
The following package was automatically installed and is no longer required:
  libcrypt-dev
Use 'sudo apt autoremove' to remove it.

Upgrading:
  dirmngr  gnupg  gnupg-l10n  gpg  gpg-agent  gpg-wks-client  gpgconf  gpgsm

Summary:
  Upgrading: 8, Installing: 0, Removing: 0, Not Upgrading: 1728
  Download size: 0 B / 2,957 kB
  Freed space: 31.7 kB
```

Key Generated :

Keyy list :

```
┌──(kali㉿kali)-[~/Desktop]
└─$ gpg --list-keys
gpg: checking the trustdb
gpg: marginals needed: 3  completes needed: 1  trust model: pgp
gpg: depth: 0  valid:   1  signed:   0  trust: 0-, 0q, 0n, 0m, 0f, 1u
gpg: next trustdb check due at 2037-06-21
/home/kali/.gnupg/pubring.kbx
-------------------------------
pub   ed25519 2026-04-04 [SC] [expires: 2037-06-21]
      F6B4BA6B4257A6D32ED7B2C5C37FC16DE795C3E2
```

New file

```
kali@kali: ~/Desktop
Session  Actions  Edit  View  Help
  GNU nano 8.6                    message.txt *
This is a digitally signed message.
```

Message Verified

```
Session  Actions  Edit  View  Help
  GNU nano 8.6                          message.txt
-----BEGIN PGP SIGNED MESSAGE-----
Hash: SHA512


-----BEGIN PGP SIGNATURE-----

iHQEARYKAB0WIQT2tLprQlem0y7XssXDf8Ft55XD4gUCadDs6wAKCRDDf8Ft55XD
4rdlAPjGtdZttCZJ1ecuF5J5sCzjz8KzndldcFeRhn0aqLLMAP0ZqFgW3nW04O4h
FfmpltNhb5tOHfqik2nDg+x1ZR6uAA==
=KsUC
-----END PGP SIGNATURE-----
```

I tempered message and its not verified

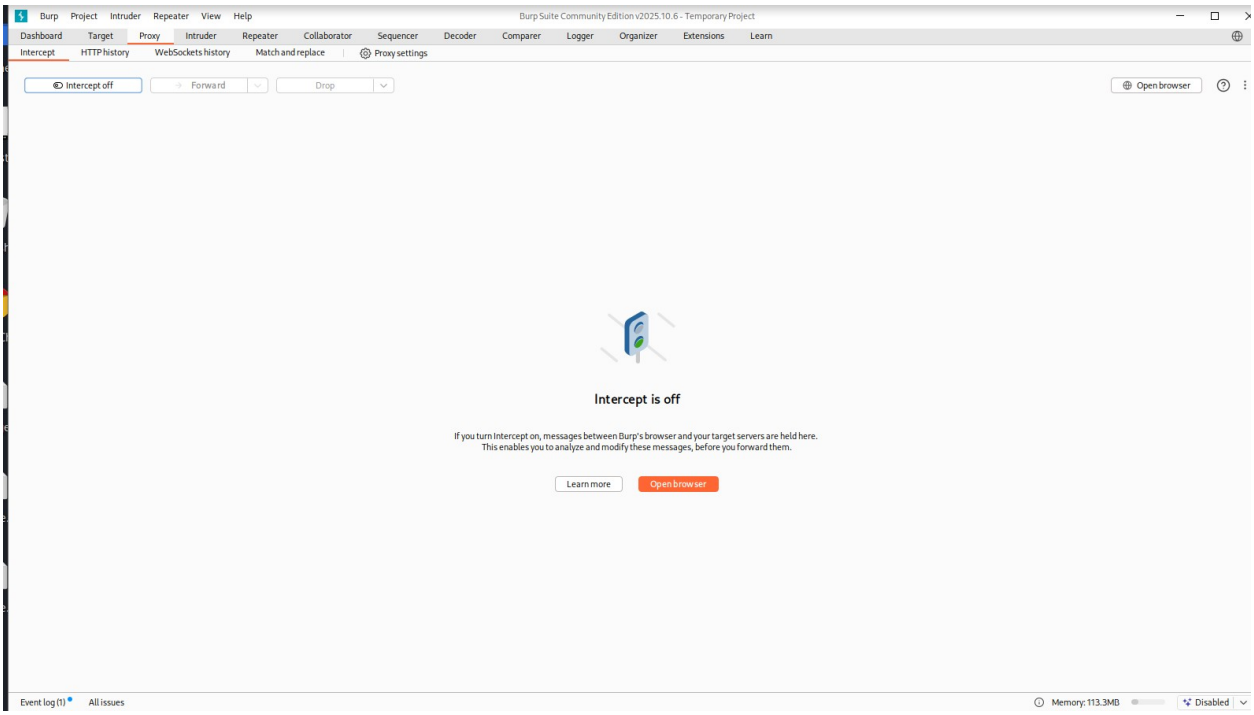
```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~/Desktop]
└─$ gpg --verify message.txt.asc
gpg: Signature made Sat 04 Apr 2026 06:49:20 AM EDT
gpg:                using EDDSA key F6B4BA6B4257A6D32ED7B2C5C37FC16DE795C3E2
gpg: Good signature from "tayyab (test) <trixsolution1@gmail.com>" [ultimate]
gpg: WARNING: not a detached signature; file 'message.txt' was NOT verified!

┌──(kali㉿kali)-[~/Desktop]
└─$
```

PART 2 — LAB TASKS

Graded Lab Tasks Note: The instructor can design graded lab activities according to the level of difficulty and complexity of the solved lab activities.

Lab Task 1

Perform Username enumeration via different responses

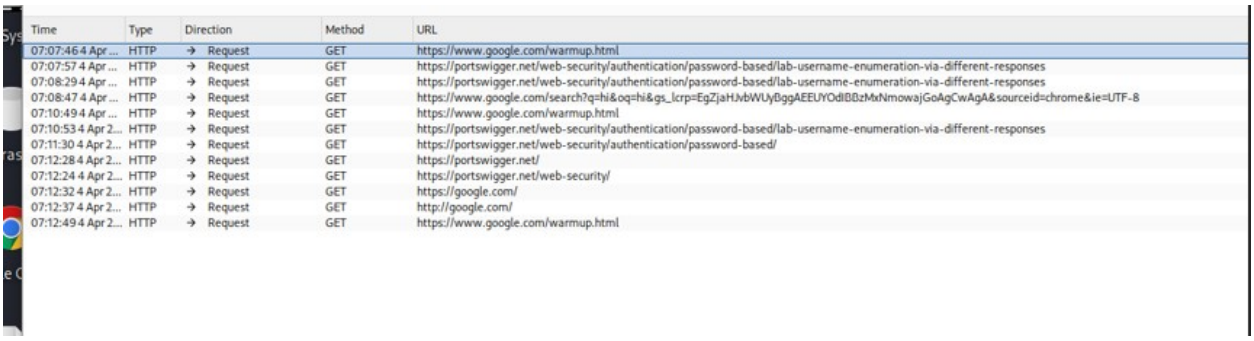


Its Sending requests but page is not loading

Request

Pretty Raw Hex

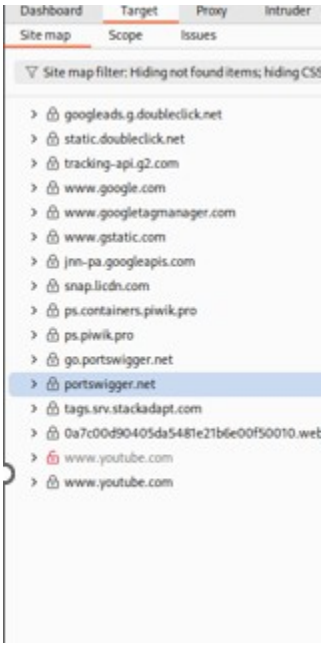
```
1  GET /warmup.html HTTP/1.1
2  Host: www.google.com
3  Sec-Ch-Ua: "Not_A Brand";v="99", "Chromium";v="142"
4  Sec-Ch-Ua-Mobile: ?0
5  Sec-Ch-Ua-Platform: "Linux"
6  Accept-Language: en-US,en;q=0.9
7  Upgrade-Insecure-Requests: 1
8  User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36
9  Sec-Purpose: prefetch;prerender
10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 X-Client-Data: CLjcygE=
12 Sec-Fetch-Site: none
13 Sec-Fetch-Mode: navigate
14 Sec-Fetch-User: ?1
15 Sec-Fetch-Dest: document
16 Accept-Encoding: gzip, deflate, br
17 Priority: u=0, i
18 Connection: keep-alive
19
```

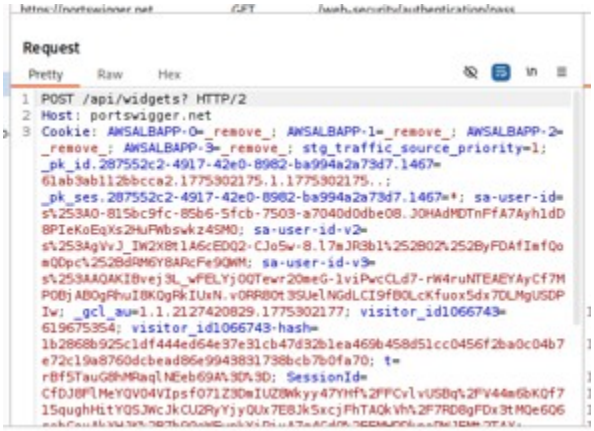


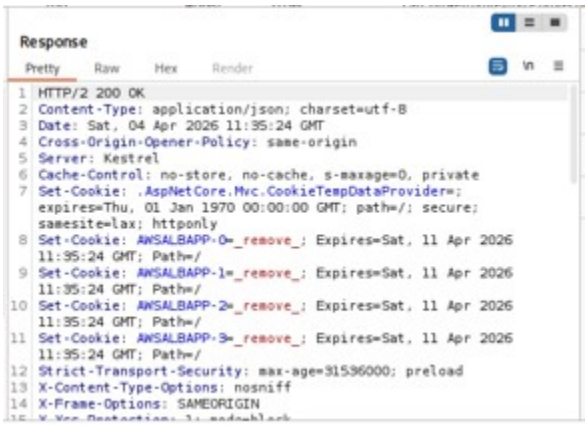
Time	Type	Direction	Method	URL
07:07:46 4 Apr ...	HTTP	→ Request	GET	https://www.google.com/warmup.html
07:07:57 4 Apr ...	HTTP	→ Request	GET	https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses
07:08:29 4 Apr ...	HTTP	→ Request	GET	https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses
07:08:47 4 Apr ...	HTTP	→ Request	GET	https://www.google.com/search?q=hi&oq=hi&gs_lcrp=EgZjaHJvbWUyBggAEEUYOdIBBzMxNmowajGoAgCwAgA&sourceid=chrome&ie=UTF-8
07:10:49 4 Apr ...	HTTP	→ Request	GET	https://www.google.com/warmup.html
07:10:53 4 Apr 2...	HTTP	→ Request	GET	https://portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses
07:11:30 4 Apr 2...	HTTP	→ Request	GET	https://portswigger.net/web-security/authentication/password-based/
07:12:28 4 Apr 2...	HTTP	→ Request	GET	https://portswigger.net/
07:12:24 4 Apr 2...	HTTP	→ Request	GET	https://portswigger.net/web-security/
07:12:32 4 Apr 2...	HTTP	→ Request	GET	https://google.com/
07:12:37 4 Apr 2...	HTTP	→ Request	GET	http://google.com/
07:12:49 4 Apr 2...	HTTP	→ Request	GET	https://www.google.com/warmup.html

Lab Task 2

Perform broken brute-force protection, IP block







```
Response
Pretty   Raw   Hex   Render
1  HTTP/2 200 OK
2  Content-Type: application/json; charset=utf-8
3  Date: Sat, 04 Apr 2026 11:35:24 GMT
4  Cross-Origin-Opener-Policy: same-origin
5  Server: Kestrel
6  Cache-Control: no-store, no-cache, s-maxage=0, private
7  Set-Cookie: .AspNetCore.Mvc.CookieTempDataProvider=;
   expires=Thu, 01 Jan 1970 00:00:00 GMT; path=/; secure;
   samesite=lax; httponly
8  Set-Cookie: AWSALBAPP-0=_remove_; Expires=Sat, 11 Apr 2026
   11:35:24 GMT; Path=/
9  Set-Cookie: AWSALBAPP-1=_remove_; Expires=Sat, 11 Apr 2026
   11:35:24 GMT; Path=/
10 Set-Cookie: AWSALBAPP-2=_remove_; Expires=Sat, 11 Apr 2026
   11:35:24 GMT; Path=/
11 Set-Cookie: AWSALBAPP-3=_remove_; Expires=Sat, 11 Apr 2026
   11:35:24 GMT; Path=/
12 Strict-Transport-Security: max-age=31536000; preload
13 X-Content-Type-Options: nosniff
14 X-Frame-Options: SAMEORIGIN
```

Burp suite during intercept on is sending many request to because its acting as man in middle

Lab Task 3

Create a secure environment for testing and demonstrating password-based authentication attacks. Set up a web application with password-based authentication. Use applications like OWASP Juice Shop, DVWA (Damn Vulnerable Web Application), or a custom application designed to have authentication vulnerabilities.

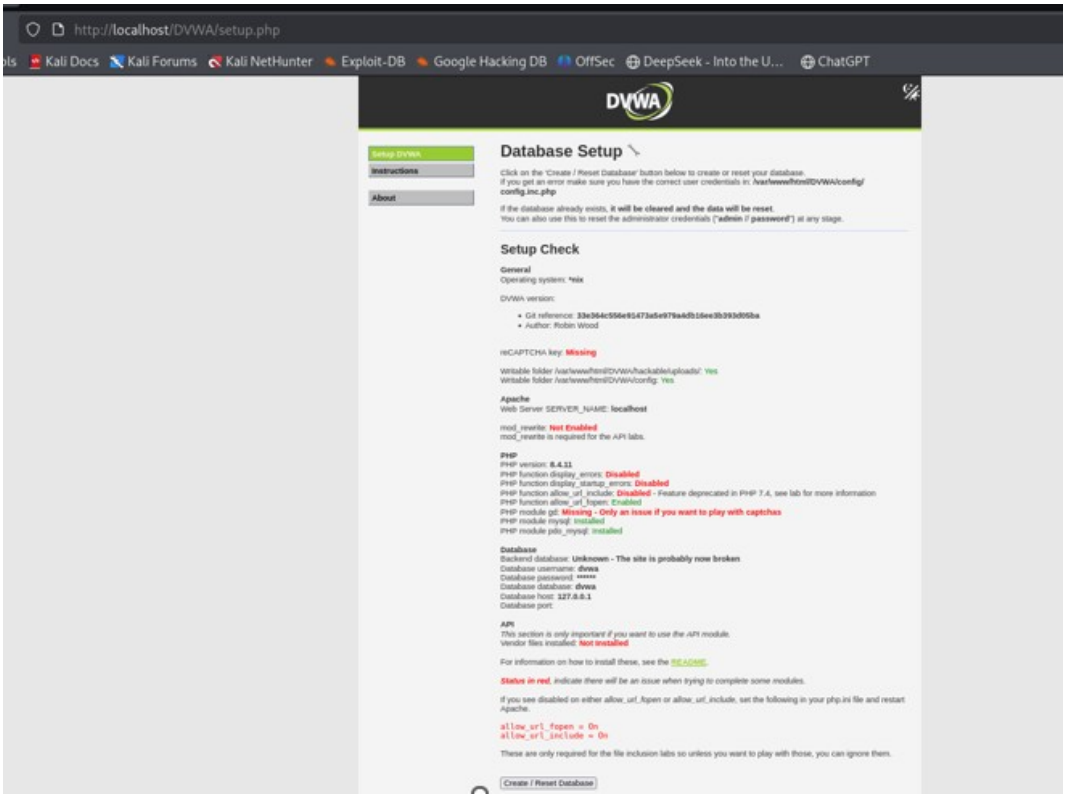
I am using DVWA tool for it

```
┌──(kali㉿kali)-[~]
└─$ sudo service mariadb start

┌──(kali㉿kali)-[~]
└─$ git clone https://github.com/digininja/DVWA.git
Cloning into 'DVWA'...
remote: Enumerating objects: 5703, done.
remote: Counting objects: 100% (32/32), done.
remote: Compressing objects: 100% (15/15), done.
remote: Total 5703 (delta 25), reused 17 (delta 17), pack-reused 5671 (from 3)
Receiving objects: 100% (5703/5703), 2.72 MiB | 381.00 KiB/s, done.
Resolving deltas: 100% (2842/2842), done.

┌──(kali㉿kali)-[~]
└─$
```

Created database there

```
└─$ sudo chown -R www-data:www-data /var/www/html/DVWA

┌──(kali㉿kali)-[~]
└─$ sudo chmod -R 755 /var/www/html/DVWA

┌──(kali㉿kali)-[~]
└─$ sudo mysql
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 31
Server version: 11.8.6-MariaDB-4 from Debian -- Please help get to 10k stars at https://g

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> CREATE DATABASE dvwa;
Query OK, 1 row affected (0.001 sec)

MariaDB [(none)]> CREATE USER 'dvwa'@'localhost' IDENTIFIED BY 'password';
Query OK, 0 rows affected (0.030 sec)

MariaDB [(none)]> GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwa'@'localhost';
Query OK, 0 rows affected (0.018 sec)

MariaDB [(none)]> FLUSH PRIVILEGES;
Query OK, 0 rows affected (0.000 sec)

MariaDB [(none)]> EXIT;
```

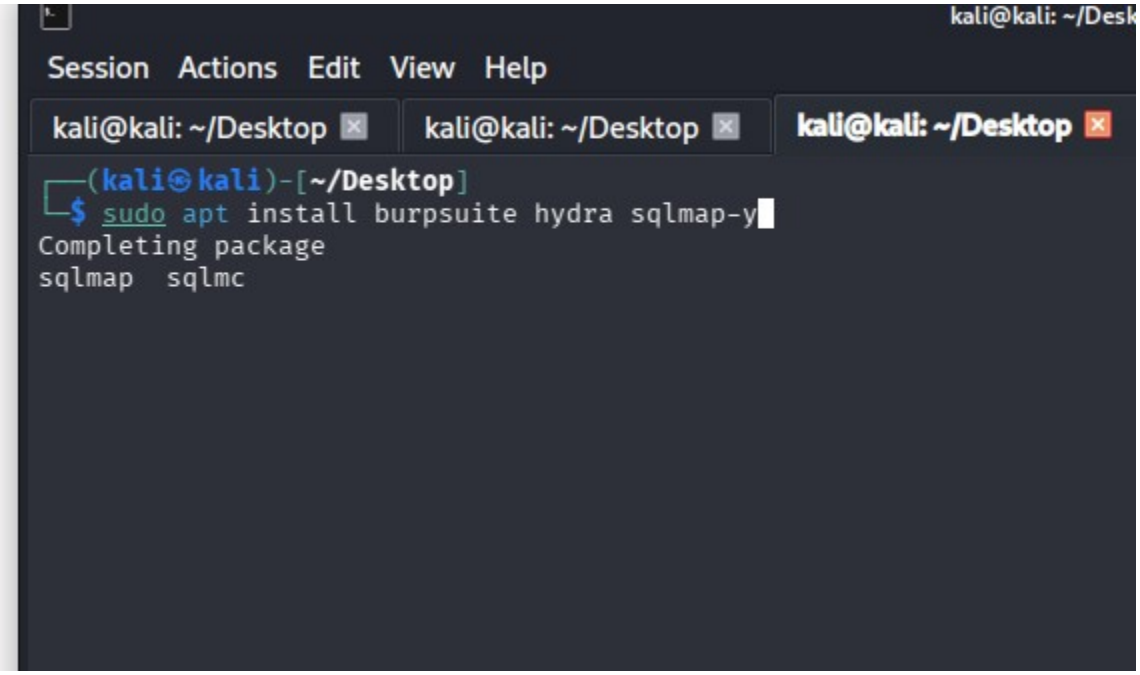
Db environment setuped



Lab Task 4

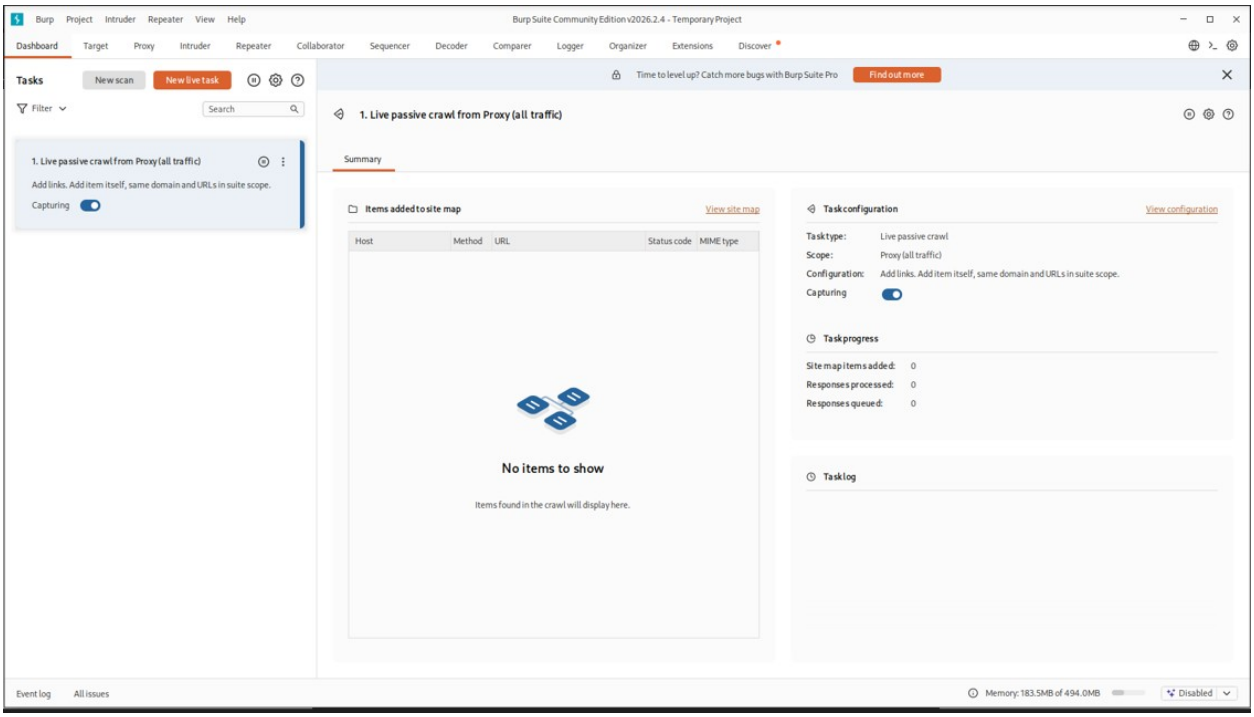
Install and configure tools for performing attacks, such as Burp Suite, Hydra, or SQLMap. Provide screenshots showing the web application setup and the installation of testing tools.

Installing all 4 tools




```
$ sudo apt install burpsuite hydra sqlmap -y
burpsuite is already the newest version (2026.2.4-0kali1).
hydra is already the newest version (9.6-3).
sqlmap is already the newest version (1.10.3-1).
sqlmap set to manually installed.
The following packages were automatically installed and are no longer required:
  libavfilter10            libgav1-1                libonnx1t64                libpostproc58      libxnnpack0.20241108
  libconfig-inifiles-perl  libgdk-pixbuf2.0-bin     libonnxruntime-providers   librubberband2     libzxing3
  libcrypt-dev             libmjpegutils-2.1-0t64   libonnxruntime1.21         libsframe2         mesa-vdpau-drivers
  libdlt2                  libmpeg2encpp-2.1-0t64   libplacebo351              libsphinxbase3t64  pocketsphinx-en-us
  libdnnl3.6               libmplex2-2.1-0t64       libpocketsphinx3           libvdpau-va-gl1    vdpau-driver-all
Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 758

(kali㉿kali)-[~/Desktop]
$
```

Burpsuite installed



Hydra Installed

```
└─$ hydra -h
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
al purposes (this is non-binding, these *** ignore laws and ethics anyway).

Syntax: hydra [[[-l LOGIN|-L FILE] [-p PASS|-P FILE]] | [-C FILE]] [-e nsr] [-o FILE] [-t TASKS] [-M FILE [-T TASKS]] [-w TIME
TIME] [-f] [-s PORT] [-x MIN:MAX:CHARSET] [-c TIME] [-ISOuvVd46] [-m MODULE_OPT] [service://server[:PORT][/OPT]]

Options:
  -R        restore a previous aborted/crashed session
  -I        ignore an existing restore file (don't wait 10 seconds)
  -S        perform an SSL connect
  -s PORT   if the service is on a different default port, define it here
  -l LOGIN or -L FILE  login with LOGIN name, or load several logins from FILE
  -p PASS  or -P FILE  try password PASS, or load several passwords from FILE
  -x MIN:MAX:CHARSET  password bruteforce generation, type "-x -h" to get help
  -y        disable use of symbols in bruteforce, see above
  -r        use a non-random shuffling method for option -x
  -e nsr    try "n" null password, "s" login as pass and/or "r" reversed login
  -u        loop around users, not passwords (effective! implied with -x)
  -C FILE   colon separated "login:pass" format, instead of -L/-P options
  -M FILE   list of servers to attack, one entry per line, ':' to specify port
  -D XofY   Divide wordlist into Y segments and use the Xth segment.
  -o FILE   write found login/password pairs to FILE instead of stdout
  -b FORMAT specify the format for the -o FILE: text(default), json, jsonv1
  -f / -F   exit when a login/pass pair is found (-M: -f per host, -F global)
  -t TASKS  run TASKS number of connects in parallel per target (default: 16)
  -T TASKS  run TASKS connects in parallel overall (for -M, default: 64)
  -w / -W TIME  wait time for a response (32) / between connects per thread (0)
  -c TIME   wait time per login attempt over all threads (enforces -t 1)
  -4 / -6   use IPv4 (default) / IPv6 addresses (put always in [] also in -M)
```

Sql Map Installed Also

```
┌──(kali㉿kali)-[~/Desktop]
└─$ sqlmap --version
1.10.3#stable

┌──(kali㉿kali)-[~/Desktop]
└─$
```

DVWA SETUPED:

http://localhost/DVWA/setup.php

Kali Docs | Kali Forums | Kali NetHunter | Exploit-DB | Google Hacking DB | OffSec | DeepSeek - Into the U... | ChatGPT

DVWA

Setup DVWA
Instructions
About

Database Setup

Click on the 'Create / Reset Database' button below to create or reset your database.
If you get an error make sure you have the correct user credentials in: **/var/www/html/DVWA/config/config.inc.php**

If the database already exists, **it will be cleared and the data will be reset**.
You can also use this to reset the administrator credentials ("**admin // password**") at any stage.

Setup Check

General
Operating system: ***nix**

DVWA version:

- Git reference: **33e364c556e91473a5e979a4db16ee3b393d05ba**
- Author: Robin Wood

reCAPTCHA key: **Missing**

Writable folder /var/www/html/DVWA/hackable/uploads/: Yes
Writable folder /var/www/html/DVWA/config: Yes

Apache
Web Server SERVER_NAME: **localhost**

mod_rewrite: **Not Enabled**
mod_rewrite is required for the API labs.

PHP
PHP version: **8.4.16**
PHP function display_errors: **Disabled**
PHP function display_startup_errors: **Disabled**
PHP function allow_url_include: **Disabled** - Feature deprecated in PHP 7.4, see lab for more information
PHP function allow_url_fopen: Enabled
PHP module gd: Installed
PHP module mysql: Installed
PHP module pdo_mysql: Installed

Database
Backend database: **Unknown - The site is probably now broken**
Database username: **dvwa**
Database password: ******
Database database: **dvwa**
Database host: **127.0.0.1**
Database port:

API

Lab Task 5

Perform attacks to exploit vulnerabilities in the password-based authentication system. Use tools like Hydra or Burp Suite to perform a brute-force attack on the login page. Document how different combinations of passwords are tested and the effectiveness of this attack.

Used a Simple Local Login (Python HTTP server)

Created a fake login server

Create file:

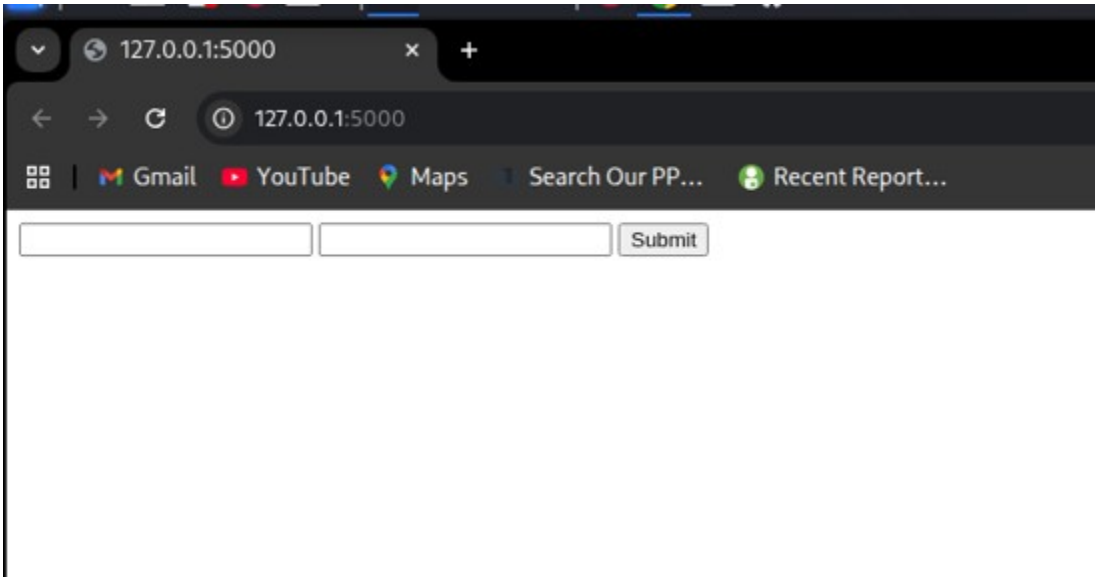
nano server.py

Pasted this code to create a login server

```
from flask import Flask, request

app = Flask(__name__)

USERNAME = "admin"
PASSWORD = "password"

@app.route('/', methods=['GET', 'POST'])
def login():
    if request.method == 'POST':
        user = request.form.get('username')
        pwd = request.form.get('password')

        if user == USERNAME and pwd == PASSWORD:
            return "Login successful"
        else:
            return "Login failed"

    return '''
    <form method="POST">
        <input name="username">
        <input name="password" type="password">
        <input type="submit">
    </form>
    '''
```

```
app.run(host='0.0.0.0', port=5000)
```

python3 server.py (command to start it)



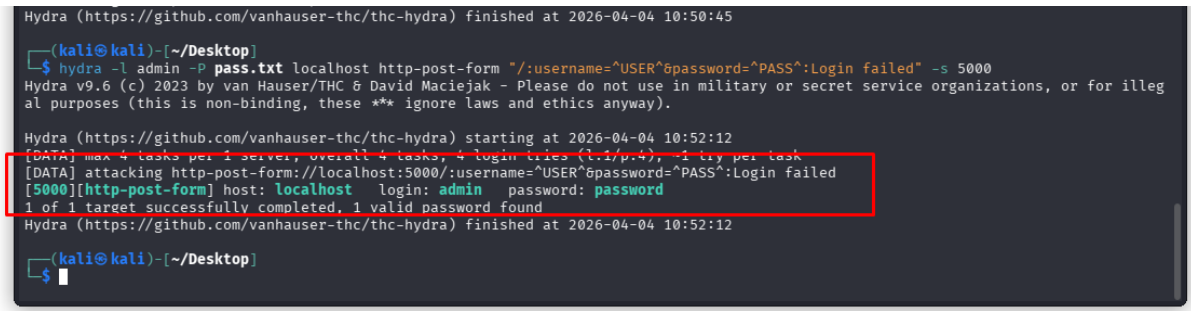
Its running

Now doing Hydra Brute Force

Creating password list

nano pass.txt

Finally Successfully Found the Password by brute forcing

Command used :

hydra -l admin -P pass.txt localhost http-post-form "/:username=^USER^&password=^PASS^:Login failed" -s 5000